Airtel

2019 Incident

Case Study

Airtel Mobile API Data Exposure

Krupa Gurav
24102C2005

Web & API Security

Case Study Overview

Organization: Bharti Airtel
Year: 2019
Application: Airtel Mobile Application
Security Area: Web / API Application Security
Vulnerability: Insecurely Exposed Testing API
Discovered by: Security Researcher Ehraz Ahmed

What Happened?

In December 2019, security researcher Ehraz Ahmed identified a vulnerability in Airtel's mobile application API. A non-production testing API was left exposed and accessible, potentially returning sensitive subscriber information. Airtel confirmed the issue existed in a testing API and patched it after responsible disclosure.

-

What Was Exposed

- Full name
- Gender
- Email address
- Date of birth
- Residential address
- Subscription and network information
- Activation date
- Prepaid/postpaid status
- IMEI number

Security Problem

The major problem was the exposure of a testing API that could retrieve sensitive production-related customer information.

Core security weaknesses

Improper Asset Management

Excessive Data Exposure

Insufficient API Access Controls

OWASP mapping

Primary: OWASP API9:2019 – Improper Assets Management

Attack Analysis

Attacker / Researcher

↓

Identify Airtel Mobile App API

↓

Discover Accessible Testing Endpoint

↓

Send API Request

↓

API Processes Request

↓

Customer Information Retrieved

↓

Sensitive Data Exposure

Impact Analysis

Confidentiality
Exposure of:

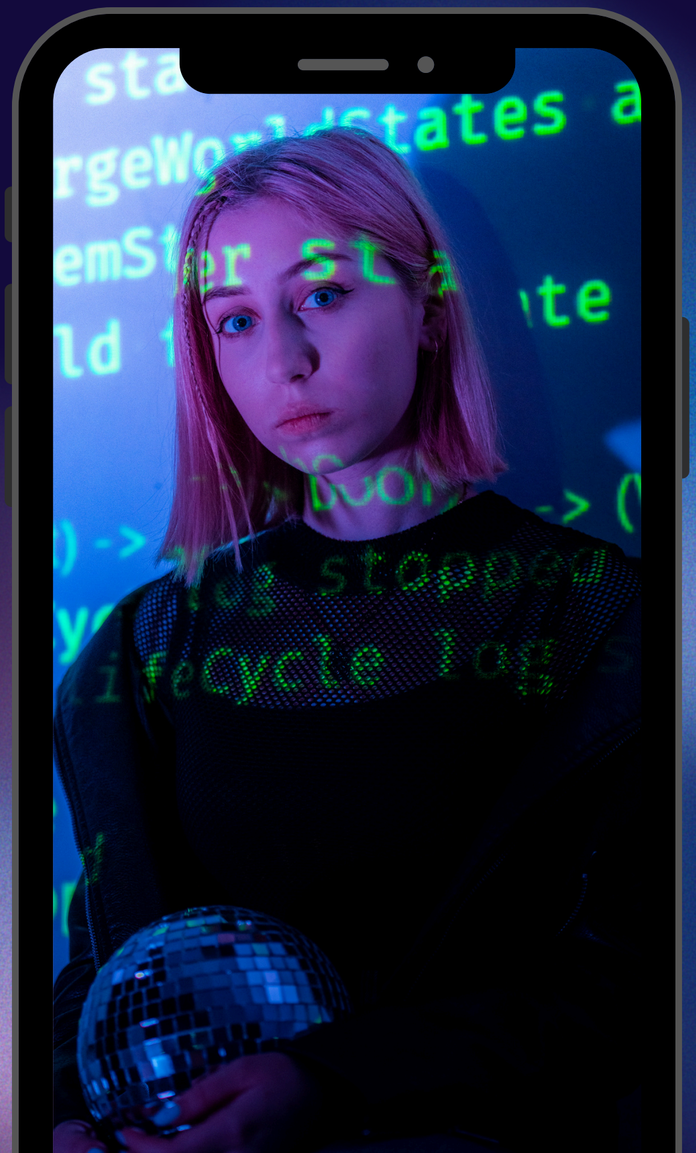
- Personal information
- Email addresses
- Residential addresses
- Date of birth
- Subscription information
- Device identifiers such as IMEI

Identity Theft
Exposed information could make:

- Phishing attacks
- Targeted scams
- Social engineering
- Spam

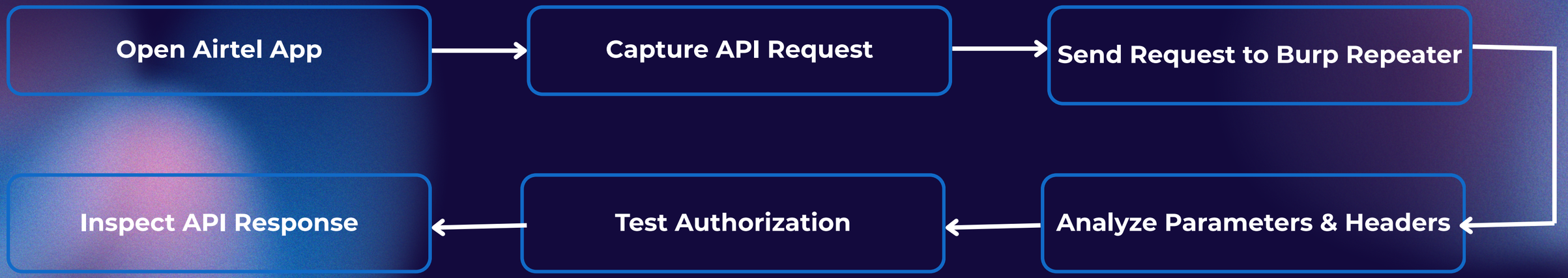
Business Impact
Potential consequences include:

- Loss of customer trust
- Regulatory/privacy concerns
- Reputation damage
- Increased incident-response costs



Security Testing & Detection

Burp Suite Testing Workflow



- OWASP ZAP → API/web vulnerability testing
- Burp Suite → Request/response interception and authorization testing
- Postman → API functional/security testing
- Swagger/OpenAPI → API inventory and specification review

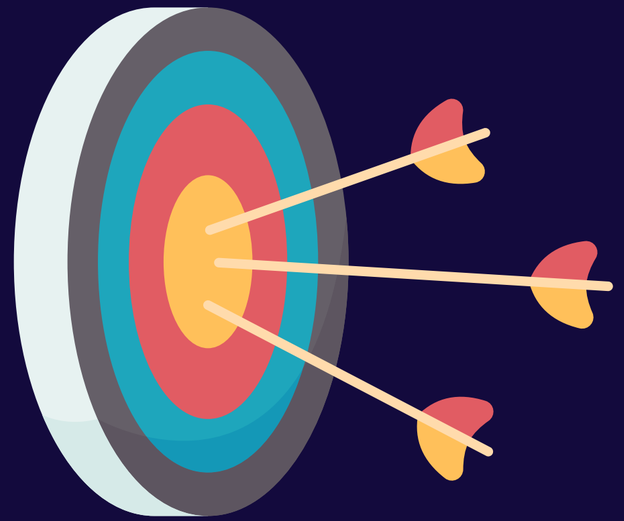
Prevention & Secure API Design

Strong Authentication

Minimize API responses

API Inventory

Security Testing



THANK YOU

-